

Eradication Phase

4/15/26 1:56 PM

SUMMARY:

Purpose: Completely remove attacker access and prevent reinfection.

When: After full scoping from host + network analysis.

Core Rule: Blocking alone is not enough — you must identify every infected system and all persistence.

Key Steps:

- 1. Scope infected hosts** — Use **tcpdump** on PCAP to extract all internal IPs talking to C2.
- 2. Detect web shells** — `nmap -sS -Pn -p 8080 <subnet>`.
- 3. Find malware copies** — strings for unique strings, **YARA** rules for content-based scanning, **Velociraptor** for scale.
- 4. Block** — Firewall/ACL rules for C2 IPs and malicious domains.
- 5. Verify** — Confirm no remaining persistence (tasks, services, scripts).

Main Tools: tcpdump, nmap, strings, YARA, Velociraptor, firewalls/ACLs.

Why it matters: Incomplete eradication leads to re-infection. Network-level blocking cuts off C2 and breaks daisy-chained implants.

When to perform: After full scoping from host + network analysis. **Why:** Remove attacker access and all malware/persistence to prevent reinfection. Simply deleting files is insufficient — you must block C2 and identify every copy.

Core goal: Block attacker, scope every infected system, remove all persistence and malware instances.

Investigation Workflow (Step-by-Step Order)

- Final scoping (find all infected hosts).
- Detect web shells and persistence.
- Locate all malware copies using signatures.
- Block C2 and malicious domains.
- Verify and prepare for recovery.

1. Network Scoping (Find Infected Hosts)

- Tool:** **tcpdump** (on captured PCAP) Full pipeline:
Bash
`tcpdump -nr ext_traffic.pcap host <C2_IP> | cut -d " " -f3 | cut -d "." -f1-4 | sort -n | uniq`
Why: Extracts all internal source IPs that talked to the C2 server. These are compromised hosts.

2. Web Shell Detection

- Tool:** **nmap**
Bash
`sudo nmap -sS -Pn -p 8080 <subnet>`
Then: `cat scan.gnmap | grep open` **Why:** Finds open ports (e.g., 8080) where web shells provide persistent attacker access. -sS = SYN scan (fast), -Pn = skip ping.

3. Malware File Scoping

- Tool:** **strings**
Bash
`strings malware.exe | more`
or with length filter: `strings -n 10 malware.exe` **Why:** Extracts readable strings (compiler info, unique phrases, ransom notes) to create signatures. File names can be changed, but content cannot.
- Tool:** **YARA** Create rule with strings (e.g., "Go build ID", unique phrases), then scan. **Why:** Detects malware by content across the filesystem, even if renamed.
- Tool:** **Velociraptor** (with YARA artifact, e.g., `Windows.Detection.Yara.NTFs`) **Why:** Scales scanning to all endpoints at once.

4. Blocking

- Tool:** Firewall / Network ACLs (or AWS Security Groups + NACLs) Block C2 IP (e.g., port 443) and malicious domain IP (use nslookup first). **Why:** Cuts off attacker control. Rule order matters — DENY rules before broad ALLOW. In AWS, NACLs support explicit DENY.

Effects: Attacker loses C2, implants fail, daisy-chained hosts lose connectivity. Some malware (including certain ransomware) may stop functioning without internet.

Remaining threats: Automated persistence (tasks, services) that do not require live C2.

Eradication Checklist:

- C2 IP and malicious domains blocked.
- All infected hosts identified.
- All malware files and web shells located/removed.
- All persistence mechanisms eliminated.

Tools summary: tcpdump (scoping), nmap (ports), strings (signatures), YARA (detection), Velociraptor (scale), nslookup (domains), firewalls/ACLs (blocking).

Key takeaway: Eradication requires complete scoping + network-level blocking before recovery.